LABORATOIRE CTF 2026

CTF 1 · Messagerie et SSH

Découverte et exploitation des services réseau

Conteneur : menu « ordre » n°58 (ctf_creer.sh), choix CTF1 · énoncé d'origine remis en forme le 07/10/2026, captures d'écran reprises sans retouche.

Avant de commencer. Ce document ne contient aucune adresse réseau réelle : il doit pouvoir servir dans n'importe quelle salle. Deux notations reviennent partout, remplacez-les au fur et à mesure.

— **${TARGET_IP}** : l'adresse IP de la machine cible. Votre professeur vous la communique ; elle est la même pendant tout le lab.

— **${MON_IP}** : l'adresse IP de VOTRE machine Kali. Pour la connaître : `ip -br addr show`.

Exemple concret. Si votre professeur vous donne la cible `192.0.2.25`, alors `ping ${TARGET_IP}` se tape `ping 192.0.2.25` — jamais `ping $192.0.2.25`, ni `ping [192.0.2.25]`, ni `ping TARGET_IP`. De même, `ssh utilisateur@${TARGET_IP}` se tape avec le VRAI identifiant que vous avez trouvé, par exemple `ssh alice@192.0.2.25` — jamais `ssh user@....` L'adresse 192.0.2.25 n'est qu'un exemple : la vôtre sera différente.

Objectifs pédagogiques

— Maîtriser les techniques de base de reconnaissance réseau

— Comprendre les vulnérabilités liées aux services mal sécurisés

— Appréhender les risques des mots de passe faibles

— Mettre en pratique des outils de sécurité offensive

— Comprendre l'importance des bonnes pratiques de sécurité

Prérequis

— Machine Kali Linux opérationnelle

— Notions de base en lignes de commandes Linux

— Compréhension des protocoles réseau de base (SSH, POP3)

Durée estimée

tout au plus 2 heures

NB : Bonnes pratiques de sécurité

Dans ce TP, nous allons exploiter des faiblesses courantes. Pour éviter ces vulnérabilités en

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

environnement réel :

Évitez les identifiants évidents comme "admin", "root", "user" Utilisez des mots de passe complexes (min. 12 caractères, majuscules, minuscules, chiffres, caractères spéciaux) Testez la robustesse de vos mots de passe sur : https://www.security.org/how-secure-is-my-password/ Activez l'authentification à deux facteurs quand c'est possible Limitez le nombre de tentatives de connexion Surveillez les logs de connexion

Un mot de passe comme "Password123" peut être cracké en quelques secondes, alors qu'un mot de passe comme "K9$mP2#vL9pN" nécessiterait plusieurs siècles avec les moyens actuels.

1. Reconnaissance initiale

1.1 Préparation de l'environnement

Démarrez votre machine Kali Linux qui servira à attaquer Donnez à votre machine Kali l'adresse ${MON_IP} indiquée par votre professeur (une adresse libre du même réseau que la cible).

Ouvrez un terminal (icône en haut à gauche de la barre des tâches)

1.2 Scan de ports avec Nmap

```
nmap ${TARGET_IP}
```

Attention : Remplacez ${TARGET_IP} par l'adresse IP de votre cible.

Votre professeur vous communique cette adresse.

2. Exploitation du service POP3

2.1 Attaque par dictionnaire avec Hydra

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt.gz ${TARGET_IP} pop3
-V
```

Paramètres utilisés :

-l admin : Spécifie le nom d'utilisateur à tester -P /usr/share/wordlists/rockyou.txt.gz : Utilise le dictionnaire rockyou pop3 : Spécifie le protocole ciblé -V : Mode verbeux pour voir la progression

2.2 Exploitation du compte POP3

Objectif : Une fois le mot de passe obtenu, nous allons nous connecter au serveur de messagerie POP3 pour extraire des informations sensibles des emails.

La commande nc (netcat) est un outil réseau polyvalent qui permet d'établir des connexions TCP/UDP. Le port 110 est le port standard pour le protocole POP3.

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
nc ${TARGET_IP} 110
user admin
pass <mot_de_passe_trouvé>
```

Exploration des emails :

— Utilisez list pour voir tous les messages disponibles

— Utilisez retr <numéro> pour lire chaque message

— Votre objectif est de trouver un nom d'utilisateur qui nous servira pour la prochaine étape

> Astuce : Lisez attentivement chaque email, ils peuvent contenir des informations cruciales pour la suite de l'attaque.

3. Exploitation du service SSH

3.1 Attaque du compte SSH

Maintenant que nous avons trouvé un nom d'utilisateur dans les emails, nous allons tenter de compromettre son compte SSH :

```
hydra -l ${IDENTIFIANT} -P /usr/share/wordlists/rockyou.txt.gz
${TARGET_IP} ssh -V
```

> **Attention :** Si la commande ne répond pas après 30 secondes, relancez-la.

3.2 Connexion SSH et recherche du flag

Objectif : Une fois connecté en SSH, nous devons prouver notre réussite en trouvant un fichier spécial nommé "flag.txt".

Connectez-vous en SSH :

```
ssh user@${TARGET_IP}
```

vous pourrez éventuellement

Utilisez cat flag.txt pour lire son contenu

> **NB :** Pourquoi un flag ? : Dans les exercices de sécurité, un "flag" est une chaîne de caractères unique qui prouve que vous avez réussi à atteindre un certain objectif. C'est comme un trophée numérique !

Conclusion et bonnes pratiques

Points clés à retenir

— La reconnaissance est une étape cruciale en sécurité offensive

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

— Les services mal sécurisés peuvent être une porte d'entrée

— Les mots de passe faibles sont une vulnérabilité majeure

Limites en environnement réel

— Les attaques par dictionnaire peuvent prendre beaucoup de temps

— L'efficacité dépend de la qualité du dictionnaire utilisé

— Rockyou est un dictionnaire basique mais populaire dans Kali

Attention : Protection contre le brute force

Pour protéger vos services contre ce type d'attaque :

— Configurez fail2ban pour bloquer les IP après plusieurs échecs de connexion à ssh

— Limitez les connexions simultanées

— Envoyez des alertes en cas de multiples échecs de connexion

— Préférez les clés SSH aux mots de passe quand c'est possible

Pour aller plus loin

— Explorer d'autres dictionnaires de mots de passe

— Étudier les mécanismes de protection contre le brute-force

— Comprendre les bonnes pratiques de sécurisation des services

Rappel légal : Ces techniques ne doivent être utilisées que dans un cadre légal et autorisé.

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne